

EPICODE — Institute of Technology

Static & Dynamic Analysis

Analisi di un Trojan mascherato da Notepad tramite CFF Explorer, Hex Editor e Wireshark

Analisi statica delle librerie importate e sezioni PE, identificazione di WS2_32.dll e sezioni duplicate come IOC, analisi dinamica del traffico di rete con tentativo di connessione Meterpreter Reverse TCP sulla porta 9001

Studente	Mauro Picca
Data	2 Giugno 2026
Corso	EPICODE — Cybersecurity & Ethical Hacking
Modulo	S9 L2 — Malware Static & Dynamic Analysis
Ambiente	notepad-classico.exe — Trojan mascherato da editor di testo

Attività svolta esclusivamente a fini didattici in ambiente di laboratorio controllato

Cybersecurity & Ethical Hacking | EPICODE

Indice

1. Introduzione e Obiettivo	3
2. Analisi Statica — Librerie Importate	3
3. Analisi Statica — Sezioni PE	5
4. Analisi Statica — Indicatori di Rete	7
5. Analisi Dinamica — Esecuzione del Campione	8
6. Analisi Dinamica — Traffico di Rete	9
7. Conclusioni	10

1. Introduzione e Obiettivo

L'obiettivo dell'attività è stato eseguire un'analisi statica e dinamica del file eseguibile notepad-classico.exe, presente nella cartella Malware della macchina virtuale FlareVM, al fine di identificare le librerie importate, le sezioni del file PE (Portable Executable) e gli eventuali comportamenti sospetti riconducibili a codice malevolo.

L'analisi è stata condotta seguendo le due fasi metodologiche standard del malware analysis:

Analisi statica — esame del file senza eseguirlo, tramite CFF Explorer per le librerie e sezioni PE, e Hex Editor per la ricerca di stringhe sospette

Analisi dinamica — esecuzione del file in ambiente controllato e cattura del traffico di rete tramite Wireshark per osservare il comportamento reale del campione

⚠ L'analisi è stata condotta interamente su FlareVM con rete isolata. Il campione notepad-classico.exe è un trojan didattico creato appositamente per il laboratorio — non viene eseguito su sistemi reali.

2. Analisi Statica — Librerie Importate

Tramite CFF Explorer è stata analizzata la Import Directory del file eseguibile. Le librerie importate rappresentano le dipendenze del programma dal sistema operativo — analizzarle permette di capire quali funzionalità il programma può utilizzare anche prima di eseguirlo.

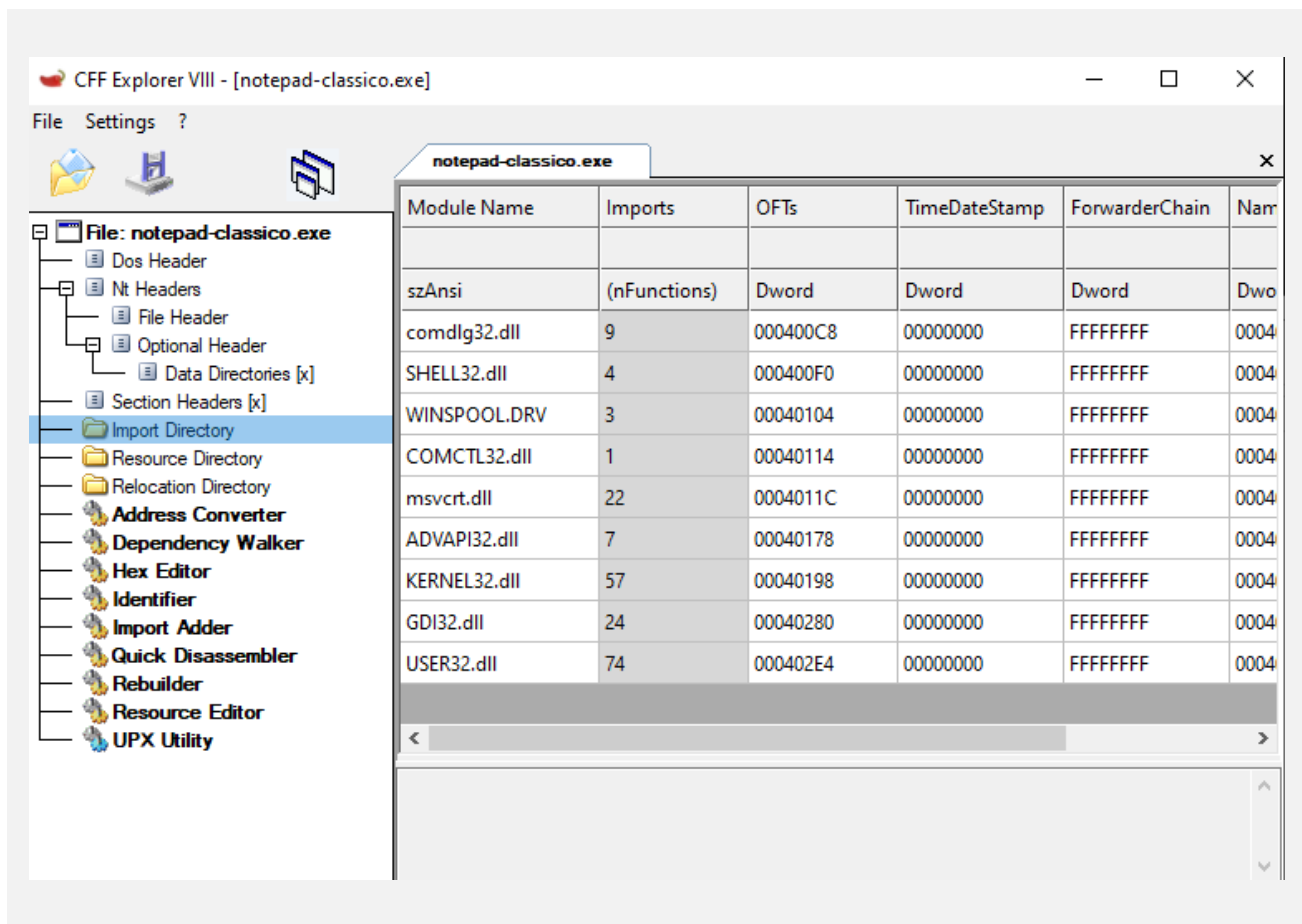


Figura 1 – CFF Explorer: Import Directory di notepad-classico.exe con le librerie importate.

Le librerie identificate sono le seguenti:

Libreria	Descrizione	Valutazione
GDI32.dll	Graphics Device Interface — gestione grafica, testo, linee e componenti GUI	☒ Legittima — coerente con un editor di testo
KERNEL32.dll	Libreria fondamentale Windows — memoria, processi, thread, file, sincronizzazione	☒ Legittima — presente in quasi tutti gli eseguibili
USER32.dll	Gestione interfaccia utente — finestre, menu, mouse e tastiera	☒ Legittima — coerente con un'applicazione GUI
ADVAPI32.dll	Funzionalità avanzate — Registro di Windows, sicurezza, autenticazione, servizi	☐ Attenzione — può essere usata per accesso al Registro
COMDLG32.dll	Finestre di dialogo standard — Apri, Salva con nome, Stampa, Trova	☒ Legittima — coerente con un editor di testo
SHELL32.dll	Interazione con la shell Windows — icone, associazioni file, Esplora Risorse	☒ Legittima — tipica di applicazioni Windows

L'insieme di queste librerie risulta compatibile con il comportamento di un normale Blocco Note di Windows. Tuttavia, la sola presenza di librerie legittime non esclude la presenza di codice malevolo all'interno dell'eseguibile: un trojan può importare le stesse librerie di un'applicazione legittima per mantenere la copertura.

💡 La presenza di ADVAPI32.dll merita attenzione: questa libreria fornisce accesso al Registro di Windows e alle API di sicurezza. In un malware viene spesso usata per creare chiavi di persistenza (HKCU\...\Run) o per interagire con i servizi di sistema.

3. Analisi Statica — Sezioni PE

L'analisi delle sezioni del file PE (Portable Executable) tramite CFF Explorer ha rivelato la struttura interna dell'eseguibile. Un file PE standard è composto da sezioni ben definite, ciascuna con uno scopo specifico.

Name	Virtual Size	Virtual Address	Raw Size	Raw Address	Reloc Address	Linenumbers	Relocations N...
Byte[8]	Dword	Dword	Dword	Dword	Dword	Dword	Word
.text	00007748	00001000	00007800	00000400	00000000	00000000	0000
.data	00001BA8	00009000	00000800	00007C00	00000000	00000000	0000
.rsrc	00008DB4	0000B000	00008E00	00008400	00000000	00000000	0000
.text	0002B6AC	00014000	0002B800	00011200	00000000	00000000	0000
.idata	0000113E	00040000	00001200	0003CA00	00000000	00000000	0000
.rsrc	00008DB0	00042000	00008E00	0003DC00	00000000	00000000	0000

Offset	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F	Ascii
00000000	4D	5A	90	00	03	00	00	00	04	00	00	00	FF	FF	00	00	MZ .0...0...y...
00000010	B8	00	00	00	00	00	00	00	40	00	00	00	00	00	00	00	@.....
00000020	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
00000030	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
00000040	0E	1F	BA	0E	00	B4	09	CD	21	B9	01	4C	CD	21	54	68	0 90 / i l i i Th
00000050	69	73	20	70	72	6F	67	72	61	6D	20	63	61	6E	6E	6F	is program canno
00000060	74	20	62	65	20	72	75	6E	20	69	6E	20	44	4F	53	20	t.be.run.in.DOS.
00000070	6D	6F	64	65	2E	0D	0D	0A	24	00	00	00	00	00	00	00	mode.\$
00000080	EC	85	5B	A1	A8	E4	35	F2	A8	E4	35	F2	A8	E4	35	F2	i l i a50 a50 a50
00000090	6B	EB	3A	F2	A9	E4	35	F2	6B	EB	55	F2	A9	E4	35	F2	ke o@a50keUo@a50
000000A0	6B	EB	68	F2	BB	E4	35	F2	A8	E4	34	F2	63	E4	35	F2	keho>a50 a40ca50
000000B0	6B	EB	6B	F2	A9	E4	35	F2	6B	EB	6A	F2	BF	E4	35	F2	keko@a50kejo@a50
000000C0	6B	EB	6F	F2	A9	E4	35	F2	52	69	63	68	A8	E4	35	F2	keoo@a50Rich a50
000000D0	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
000000E0	50	45	00	00	4C	01	06	00	87	52	02	48	00	00	00	00	PE .I00 .15 H...
000000F0	00	00	00	00	E0	00	0F	01	0B	01	01	00	00	40	03	00	...A.00000 .60
00000100	00	60	01	00	00	00	00	00	00	00	00	40	01	00	00	10	00
00000110	00	90	00	00	00	00	00	01	00	10	00	00	00	02	00	00	0.....
00000120	04	00	00	00	00	00	00	00	00	04	00	00	00	00	00	00	0.....
00000130	B0	AD	04	00	C8	02	00	00	9D	F4	04	00	02	00	00	80	*-0.E...c0...I
00000140	00	00	10	00	10	00	00	00	00	10	00	00	10	00	00	00	..0..0...0...0
00000150	00	00	00	10	00	00	00	00	00	00	00	00	00	00	00	00	..0..0...0...0
00000160	00	00	04	00	3E	11	00	00	00	20	04	00	E0	0D	00	00	..0..>0...0...*
00000170	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
00000180	98	F6	03	00	14	00	00	00	00	00	00	00	00	00	00	00	ic0..0.....
00000190	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
000001A0	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	

Figura 2 – CFF Explorer: Section Headers di notepad-classico.exe con le sezioni duplicate evidenziate.

Le sezioni identificate sono:

Sezione	Contenuto	Anomalia
.text	Codice eseguibile — istruzioni che la CPU esegue direttamente	⚠️ DUPLICATA — presenza di due sezioni .text
.data	Dati globali e variabili statiche utilizzate dal programma	☑️ Normale
.idata	Import Address Table (IAT) — collegamento alle funzioni delle DLL importate	☑️ Normale
.rsrc	Risorse dell'applicazione — icone, menu, stringhe di testo, elementi grafici	⚠️ DUPLICATA — presenza di due sezioni .rsrc

La presenza di due sezioni .text e due sezioni .rsrc è un indicatore critico di compromissione. In un file PE legittimo ogni sezione appare una sola volta. La duplicazione indica con alta probabilità che il file originale è stato modificato tramite iniezione di codice:

- la prima sezione .text contiene il codice originale del Notepad legittimo
- la seconda sezione .text contiene il payload malevolo iniettato successivamente
- la duplicazione di .rsrc può servire a mantenere le risorse originali per non alterare l'aspetto del programma

🔍 La duplicazione delle sezioni PE è una firma classica di tecniche di code injection come File Infector o Backdoor implantation. Strumenti come PEiD, pestudio e DIE (Detect It Easy) sono in grado di rilevare automaticamente questa anomalia durante l'analisi statica.

4. Analisi Statica — Indicatori di Rete

L'analisi del contenuto binario dell'eseguibile tramite Hex Editor ha permesso di identificare la presenza della stringa WS2_32.dll all'interno del file.

CFF Explorer VIII - [notepad-classico.exe]

File Settings ?

notepad-classico.exe

Find String: ws2_32.dll Find Reset

Match Case Unicode

Hex Find

Status: String found

Offset	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F	Ascii
00036230	6E	66	6F	00	00	57	53	32	5F	33	32	2E	64	6C	6C	00	nfo. WS2_32.dll
00036240	00	83	00	43	72	79	70	74	44	65	63	6F	64	65	4F	62	..CryptDecodeOb
00036250	6A	65	63	74	45	78	00	A4	00	43	72	79	70	74	49	6D	jectEx..CryptIm
00036260	70	6F	72	74	50	75	62	6C	69	63	4B	65	79	49	6E	66	portPublicKeyInf
00036270	6F	00	00	46	00	43	65	72	74	47	65	74	43	65	72	74	o..F.CertGetCert
00036280	69	66	69	63	61	74	65	43	6F	6E	74	65	78	74	50	72	ificateContextPr
00036290	6F	70	65	72	74	79	00	43	52	59	50	54	33	32	2E	64	roperty.CRYPT32.d
000362A0	6C	6C	00	74	00	49	6E	74	65	72	6E	65	74	43	72	61	ll..t..InternetCra
000362B0	63	6B	55	72	6C	57	00	9A	00	49	6E	74	65	72	6E	65	ckUriW..I..Interne
000362C0	74	4F	70	65	6E	57	00	6B	00	49	6E	74	65	72	6E	65	tOpenW.k..Interne
000362D0	74	43	6C	6F	73	65	48	61	6E	64	6C	65	00	72	00	49	tCloseHandle.r..I
000362E0	6E	74	65	72	6E	65	74	43	6F	6E	6E	65	63	74	57	00	nternetConnectW.
000362F0	00	9F	00	49	6E	74	65	72	6E	65	74	52	65	61	64	46	..I..InternetReadF
00036300	69	6C	65	00	00	AF	00	49	6E	74	65	72	6E	65	74	53	ile..I..InternetS
00036310	65	74	4F	70	74	69	6F	6E	57	00	00	58	00	48	74	74	etOptionW..X..Htt
00036320	70	4F	70	65	6E	52	65	71	75	65	73	74	57	00	00	5E	pOpenRequestW..^
00036330	00	48	74	74	70	53	65	6E	64	52	65	71	75	65	73	74	..HttpSendRequest
00036340	57	00	00	5A	00	48	74	74	70	51	75	65	72	79	49	6E	W..Z..HttpQueryIn
00036350	66	6F	57	00	00	57	49	4E	49	4E	45	54	2E	64	6C	6C	foW..WININET.dll
00036360	00	09	00	57	69	6E	48	74	74	70	43	72	61	63	6B	55	..WinHttpCrackU
00036370	72	6C	00	0F	00	57	69	6E	48	74	74	70	4F	70	65	6E	rl..WinHttpOpen
00036380	00	07	00	57	69	6E	48	74	74	70	43	6C	6F	73	65	48	..WinHttpCloseH
00036390	61	6E	64	6C	65	00	00	08	00	57	69	6E	48	74	74	70	andle..WinHttp
000363A0	43	6F	6E	6E	65	63	74	00	00	15	00	57	69	6E	48	74	Connect..WinHt
000363B0	74	70	52	65	61	64	44	61	74	61	00	14	00	57	69	6E	tpReadData..Win
000363C0	48	74	74	70	51	75	65	72	79	4F	70	74	69	6F	6E	00	HttpQueryOption.
000363D0	00	1A	00	57	69	6E	48	74	74	70	53	65	74	4F	70	74	..WinHttpSetOpt
000363E0	69	6F	6E	00	00	10	00	57	69	6E	48	74	74	70	4F	70	ion..WinHttpOp
000363F0	65	6E	52	65	71	75	65	73	74	00	00	17	00	57	69	6E	enRequest..Win
00036400	48	74	74	70	53	65	6E	64	52	65	71	75	65	73	74	00	HttpSendRequest.
00036410	00	16	00	57	69	6E	48	74	74	70	52	65	63	65	69	76	..WinHttpReceiv
00036420	65	52	65	73	70	6F	6E	73	65	00	00	13	00	57	69	6E	eResponse..Win
00036430	48	74	74	70	51	75	65	72	79	48	65	61	64	65	72	73	HttpQueryHeaders
00036440	00	0E	00	57	69	6E	48	74	74	70	47	65	74	50	72	6F	..WinHttpGetPro
00036450	78	79	46	6F	72	55	72	6C	00	0D	00	57	69	6E	48	74	xyForUrl..WinHt
00036460	74	70	47	65	74	49	45	50	72	6F	78	79	43	6F	6E	66	tpGetIEProxyConf
00036470	69	67	46	6F	72	43	75	72	72	65	6E	74	55	73	65	72	igForCurrentUser
00036480	00	57	49	4E	48	54	54	50	2E	64	6C	6C	00	EA	04	56	..WINHTTP.dll..eV
00036490	69	72	74	75	61	6C	41	6C	6C	6F	63	45	78	00	00	80	irtualAllocEx..I
000364A0	03	4F	70	65	6E	50	72	6F	63	65	73	73	00	C0	01	47	OpenProcess..AG
000364B0	65	74	43	75	72	72	65	6E	74	50	72	6F	63	65	73	73	etCurrentProcess
000364C0	00	02	02	47	65	74	4C	61	73	74	45	72	72	6F	72	00	..GetLastError.
000364D0	00	2E	05	57	72	69	74	65	50	72	6F	63	65	73	73	4D	..WriteProcessM

Figura 3 – Hex Editor: stringa WS2_32.dll identificata nel contenuto binario di notepad-classico.exe.

WS2_32.dll è la libreria delle API Winsock di Windows, utilizzata per implementare comunicazioni di rete basate su protocollo TCP/IP. La sua presenza come stringa nel file — prima ancora di eseguirlo — è un indicatore importante:

- un semplice editor di testo non ha motivo di aprire connessioni di rete
- la presenza di WS2_32.dll suggerisce che il payload iniettato include funzionalità di comunicazione di rete
- questo è coerente con un payload Meterpreter o una reverse shell che deve connettersi a un server C2 (Command & Control)

💡 Questa discovery tramite analisi statica anticipa il comportamento che verrà confermato dall'analisi dinamica: il file tenterà di stabilire una connessione di rete verso un host remoto. La ricerca di stringhe nel binario tramite Hex Editor o strings è una delle tecniche più veloci per ottenere IOC senza eseguire il malware.

5. Analisi Dinamica — Esecuzione del Campione

Il file notepad-classico.exe è stato eseguito all'interno della macchina virtuale FlareVM, con Wireshark già avviato in cattura sul traffico di rete. Prima dell'esecuzione è stato verificato che la rete fosse isolata per impedire che eventuali connessioni potessero raggiungere sistemi reali.

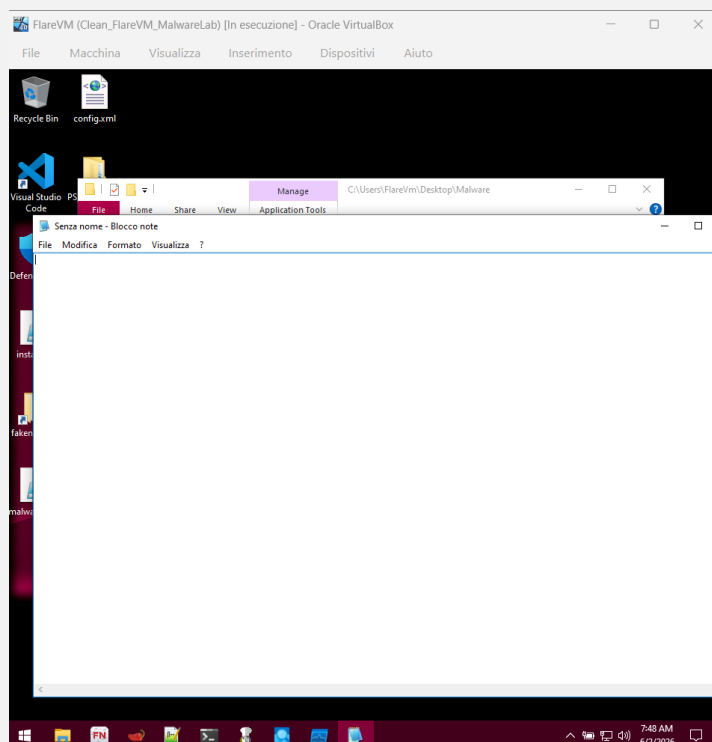


Figura 4 – Esecuzione di notepad-classico.exe su FlareVM: apertura dell'interfaccia Blocco Note senza errori visibili.

Durante l'esecuzione il programma ha mostrato il comportamento tipico di un normale Blocco Note di Windows: apertura corretta dell'interfaccia grafica, nessun messaggio di errore, nessun comportamento visivamente anomalo per l'utente.

Questo comportamento è esattamente quello atteso da un Trojan: l'applicazione ospite (Notepad) viene mantenuta funzionante per non insospettire l'utente, mentre il payload malevolo viene eseguito silenziosamente in background.

Il comportamento apparentemente legittimo è la caratteristica distintiva della categoria Trojan Horse: il malware si nasconde all'interno di un programma utile e funzionante, rendendo il rilevamento difficile senza strumenti di analisi dedicati.

6. Analisi Dinamica — Traffico di Rete

L'analisi del traffico catturato con Wireshark durante l'esecuzione del campione ha evidenziato attività di rete sulla porta TCP 9001 — porta non utilizzata da un normale editor di testo.

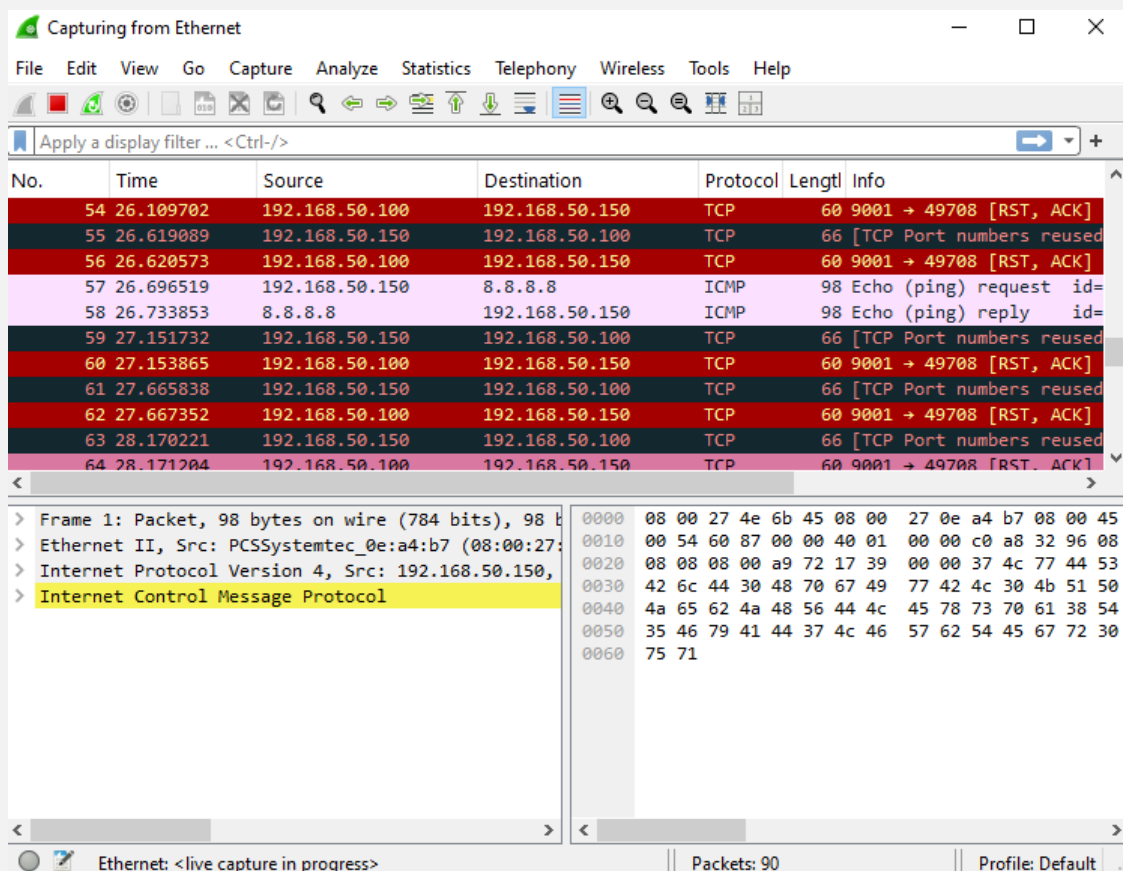


Figura 5 – Wireshark: traffico TCP sulla porta 9001 con flag RST, ACK durante l'esecuzione di notepad-classico.exe.

I dettagli del traffico osservato:

Elemento	Valore	Interpretazione
Porta destinazione	9001/TCP	Porta tipicamente associata a Meterpreter Reverse TCP
Flag TCP osservati	RST, ACK	Connessione rifiutata dal destinatario — server C2 non raggiungibile
Esito connessione	Non completata	La rete isolata ha impedito il completamento della connessione
Comportamento	Tentativo attivo	Il malware ha comunque tentato di connettersi, confermando la presenza del payload

La porta 9001 è una delle porte più comunemente usate dai payload Meterpreter Reverse TCP generati con msfvenom. Sebbene la connessione non sia stata completata — la rete isolata ha bloccato il traffico in uscita — il solo tentativo di connessione costituisce una conferma definitiva che il file esegue attività di rete non dichiarate, incompatibili con un semplice editor di testo.

⚠ Se il campione fosse stato eseguito su una macchina connessa a Internet o a una rete con un listener Metasploit attivo sulla porta 9001, la connessione sarebbe stata completata e l'attaccante avrebbe ottenuto una sessione Meterpreter con accesso completo al sistema.

7. Conclusioni

L'analisi statica e dinamica del file notepad-classico.exe ha confermato la presenza di un Trojan mascherato da editor di testo. Le evidenze raccolte nelle due fasi si completano a vicenda, fornendo un quadro completo della minaccia.

Fase	Tecnica	Indicatore Trovato	Significato
Statica	Import Directory (CFF Explorer)	ADVAPI32.dll	Possibile accesso al Registro — persistenza
Statica	Section Headers (CFF Explorer)	2x .text + 2x .rsrc	Code injection — payload iniettato nel file originale
Statica	Hex Editor (ricerca stringhe)	WS2_32.dll	Il malware implementa comunicazioni di rete
Dinamica	Wireshark — traffico TCP	Connessione TCP porta 9001	Tentativo reverse shell Meterpreter verso C2
Dinamica	Comportamento visibile	Notepad funzionante	Mascheramento Trojan — nessun segnale visivo per l'utente

La tecnica utilizzata è quella del Trojan Horse: il payload malevolo (probabilmente un Meterpreter reverse shell) è stato iniettato all'interno del file Notepad legittimo, preservandone il funzionamento per non insospettire l'utente. La connessione verso la porta 9001 dimostra che il malware era configurato per connettersi a un server C2 dell'attaccante.

Lesson Learned

- L'analisi statica va sempre eseguita prima di quella dinamica: le sezioni PE duplicate e la presenza di WS2_32.dll hanno anticipato esattamente il comportamento poi osservato con Wireshark. Analizzare prima il file senza eseguirlo riduce il rischio di attivare meccanismi di evasione o di infettare il sistema di analisi.
- La duplicazione delle sezioni PE è una firma affidabile di code injection: in un file legittimo ogni sezione appare una sola volta. Rilevare due sezioni .text o .rsrc durante il triage statico deve alzare immediatamente il livello di allerta, anche prima di qualsiasi analisi più approfondita.
- Un editor di testo che apre connessioni TCP è anomalo per definizione. Il principio del minimo privilegio applicato al network monitoring: se un processo apre una connessione verso una porta non attesa (come 9001), è un segnale da investigare immediatamente — anche se la connessione non viene completata.

☒ Tutti gli obiettivi del laboratorio sono stati raggiunti. L'analisi statica e dinamica ha permesso di identificare e caratterizzare completamente il campione notepad-classico.exe come Trojan con payload Meterpreter Reverse TCP.